

PARTIE 3 : SENSIBILISATION À LA SSI

Qu'est-ce que la SSI?

La **sécurité des systèmes d'information (SSI)** est l'ensemble des moyens techniques, organisationnels, juridiques et humains nécessaire et mis en place pour conserver, rétablir, et garantir la sécurité du Système d'information.

QUI EST CONCERNÉ PAR LA SÉCURITÉ DES SI ?

Les informaticiens

Les dirigeants

Les utilisateurs (salariés, clients...)

Tous les membres du groupe concernés par le système d'information.

POURQUOI LES PIRATES S'INTÉRESSENT-ILS AUX S.I. DES ORGANISATIONS ?

- Gains financiers** (accès à l'information, puis monétisation et revente, demande de rançon)
- Utilisation de ressources** (mise à disposition en tant que « service »)
- Espionnage** (Industriel, concurrentiel, Étatique)

COMMENT DÉFINIR LE NIVEAU DE SÉCURITÉ D'UN BIEN DU S.I. ? COMMENT ÉVALUER SI CE BIEN EST CORRECTEMENT SÉCURISÉ ?

3 critères sont retenus pour répondre à cette problématique, connus sous le nom de D.I.C.

Disponibilité : Propriété d'accessibilité au moment voulu des biens par les personnes autorisées,

Intégrité: Propriété d'exactitude et de complétude des biens et informations,

Confidentialité: Propriété des biens de n'être accessibles qu'aux personnes autorisées.

DIFFÉRENCES ENTRE SÛRETÉ ET SÉCURITÉ ?

Sûreté

ensemble de mécanismes mis en place pour assurer la continuité de fonctionnement du système dans les conditions requises

- Protection contre les dysfonctionnements et accidents involontaires

Exemple de risque : saturation d'un point d'accès, panne d'un disque, erreur d'exécution, etc.

Quantifiable statistiquement: (ex. : la durée de vie moyenne d'un disque est de X milliers d'heures)

Mesures : sauvegarde, dimensionnement, redondance des équipements...

Sécurité

ensemble de mécanismes destinés à protéger l'information des utilisateurs n'ayant pas l'autorisation de la manipuler et d'assurer les accès autorisés.

- Protection contre les actions malveillantes volontaires

Exemple de risque: blocage d'un service, modification ou vol d'informations;

Non quantifiable: Statistiquement, mais il est possible d'évaluer en amont le niveau du risque et les impacts.

Mesures: contrôle d'accès, correctifs de sécurité, configuration renforcée...

RGPD : RÈGLEMENT GÉNÉRAL SUR LA PROTECTION DES DONNÉES

Applicable depuis le 25 mai 2018

Pour donner plus de contrôle aux citoyens européens sur leur données personnelles à travers:

Le **consentement clair et explicite** de la personne concernée quant à l'utilisation de ses données personnelles ;

Le droit d'être **informé en cas de piratage** des données ;

Une **mise en œuvre plus stricte** et des **amendes** allant jusqu'à 4% du chiffre d'affaires total d'une entreprise, dans le but de décourager la violation des règles.

LA NORME ISO 27001

Système de management de la sécurité de l'information ou SMSI

Fournie un schéma de certification pouvant être appliqué au SMSI au moyen d'un audit ;

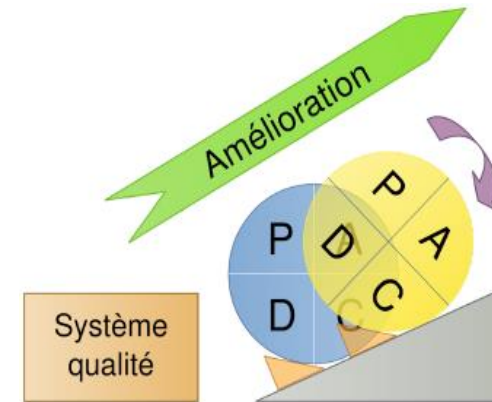
S'appuie sur une approche par processus : **PDCA**, «**Plan, Do, Check, Act**» :

- ◊ Phase Plan : identifier et évaluer les risques/ produire le document qui énumère les mesures de sécurité à appliquer ;

- ◊ Phase Do : affecter les ressources nécessaires/ former le personnel / appliquer les mesures décidées , identifier les risques résiduels,

- ◊ Phase Check : audit et revue périodiques du SMSI, qui produisent des constats et permettent d'imaginer des corrections et des améliorations,

- ◊ Phase Act : prendre les mesures qui permettent de réaliser les corrections et les améliorations dont l'opportunité a été mise en lumière par la phase Check / préparer une nouvelle itération de la phase Plan.



EXEMPLE: HAMEÇONNAGE

L'hameçonnage (anglais : « **phishing** ») constitue une « attaque de masse » qui vise à abuser de la « naïveté » des clients ou des employés pour récupérer leurs identifiants de banque en ligne ou leurs numéros de carte bancaire...

- 1 Réception d'un mail utilisant le logo et les couleurs de l'entreprise
- 2 Demande pour effectuer une opération comme la mise-à-jour des données personnelles ou la confirmation du mot de passe
- 3 Connexion à un faux-site identique à celui de l'entreprise et contrôlé par l'attaquant
- 4 Récupération par l'attaquant des identifiants/mots de passe (ou tout autre donnée sensible) saisie par le client sur le faux site

The image displays three overlapping screenshots of a phishing email, illustrating the steps of a phishing attack:

- Top Screenshot (LCL):** A fake email from LCL (Le Crédit Lyonnais) with a blue header. The text states: "Le test de nouveau système. Compte tenu d'accidents, notre banque a introduit chaque mois vous serez espérons votre compte permettra de réduire le personnel, ainsi que com. Avisez votre service en ligne, a été temporairement suspendu en raison de tentatives infructueuses pour accéder à votre compte en ligne. Par mesure de sécurité, nous avons décidé de désactiver temporairement votre compte, cet incident mai que je tente d'accéder à votre compte à partir d'une autre adresse IP, car le système utilisé par les fournisseurs de services Internet." A "CA" logo is also visible.
- Middle Screenshot (Société Générale):** A fake email from Société Générale with a red header. The text states: "Cher client de SOCIÉTÉ GÉNÉRALE. Le département technique de Société Générale a programmée de façon à améliorer la qualité de nos services. Nous vous demandons avec bienveillance de confirmer vos détails bancaires. <http://www.societegenerale.fr/customercare/fr>. Nous nous excusons pour tout désagrément." A "SOCIÉTÉ GÉNÉRALE" logo is visible.
- Bottom Screenshot (Verified by Visa/MasterCard):** A fake "Verified by Visa" and "MasterCard SecureCode" page. The title is "Mettre à jour de votre Carte Crédit en ligne". The text states: "Veuillez remplir l'un des deux de la forme Pour vous protéger contre l'utilisation frauduleuse de votre carte bancaire, Verified by Visa a adopté la solution SecureCode™. Une fois votre Carte de crédit est confirmé et protégé. Contre les menaces sur les Fraudes en ligne." The form includes fields for: "Nom Prénom *", "Date de Naissance *" (with dropdowns for Jour, Mois, Année), "Nom De jeune fille de votre mère? *", "Type De Carte *" (with a dropdown showing VISA and MasterCard), "Numéro de carte *", "Date d'expiration *" (with dropdowns for 01 and 09), and "Cryptogramme *". A "Valider" button is at the bottom. A footer note says: "Verified by visa vous garanti un paiement sécurisé par la technologie de cryptage SSL- En savoir plus".

EXEMPLE: INGÉNIERIE SOCIALE

L'« **ingénierie sociale** » constitue une « attaque ciblée » qui vise à abuser de la « naïveté » des employés de l'entreprise :

- pour dérober directement des informations confidentielle, ou
- pour introduire des logiciels malveillants dans le système d'information de la banque



par téléphone



par réseaux
sociaux



par e-mail

les scénarios d'ingénierie sociale sont illimités, avec pour seules limites l'imagination des attaquants et la naïveté des victimes...

POLITIQUE DE SÉCURITÉ

Élaborer des règles et des procédures.

Définir les actions à mener et les personnes à contacter.

Déterminer les rôles et les responsabilités.

→ Actions pour les utilisateurs

N'utiliser que les applications identifiées.

Respecter la confidentialité des codes d'accès.

→ Actions pour les techniciens

Avoir une bonne connaissance fonctionnelle et technique du système.

Sauvegarder régulièrement et s'assurer que ces sauvegardes soient utilisables.

→ Actions pour les responsables

S'assurer que les actions à conduire en cas de panne pourront être faites.

S'assurer que la politique de sécurité est respectée

MESURES DE SÉCURITÉ

Un Système d'Information a besoin de mécanismes de sécurité qui ont pour objectif d'assurer de garantir les propriétés DICP sur les biens de ce S.I. Voici quelques exemples de mécanismes de sécurité participant à cette garantie :

		D	I	C	P
Anti-virus	Mécanisme technique permettant de détecter toute attaque virale qui a déjà été identifiée par la communauté sécurité	✓	✓	✓	
Cryptographie	Mécanisme permettant d'implémenter du chiffrement et des signatures électroniques		✓	✓	✓
Pare-feu	Équipement permettant d'isoler des zones réseaux entre-elles et de n'autoriser le passage que de certains flux seulement	✓		✓	
Contrôles d'accès logiques	Mécanismes permettant de restreindre l'accès en lecture/écriture/suppression aux ressources aux seules personnes dûment habilitées		✓	✓	✓
Sécurité physique des équipements et locaux	Mécanismes de protection destinés à protéger l'intégrité physique du matériel et des bâtiments/bureaux.	✓	✓	✓	

Capacité d'audit

Mécanismes organisationnels destinés à s'assurer de l'efficacité et de la pertinence des mesures mises en œuvre. Participe à l'amélioration continue de la sécurité du S.I.

D I C P

✓ ✓ ✓ ✓

Clauses contractuelles avec les partenaires

Mécanismes organisationnels destinés à s'assurer que les partenaires et prestataires mettent en œuvre les mesures nécessaires pour ne pas impacter la sécurité des S.I. de leurs clients

✓ ✓ ✓ ✓

Formation et sensibilisation

Mécanismes organisationnels dont l'objectif est d'expliquer aux utilisateurs, administrateurs, techniciens, PDG, clients, grand public, etc. en quoi leurs actions affectent la sécurité des S.I. Diffusion des bonnes pratiques de sécurité.
Le cours actuel en est une illustration !

✓ ✓ ✓ ✓

DIFFÉRENCE ENTRE SAUVEGARDE ET ARCHIVAGE ?

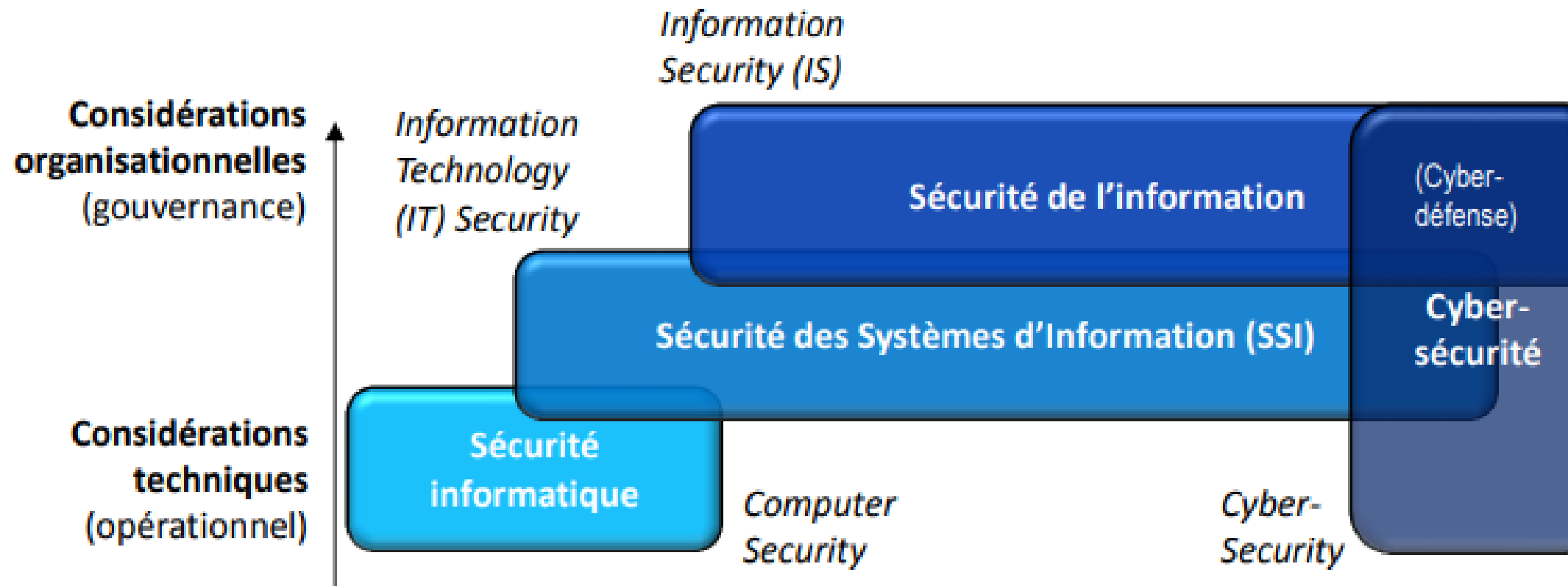
Ne pas confondre

- *Sauvegarde* : enregistrement des données dans un but de sécurité
- *Archivage* : enregistrement des données à des fins légales ou historiques

Les **sauvegardes** sont utiles principalement à :

Permettre de restaurer un système informatique suite à un incident (défaillance matériel, sinistre...).

QUELLE DIFFÉRENCE ENTRE SÉCURITÉ DE L'INFORMATION, SSI ET CYBERSÉCURITÉ ?



TD4 : TRAVAIL SÉCURITÉ